

Slide 1 — Executive Decision: TRC Approval Request

- Decision requested: Approve the proposed NovaPay CI/CD transformation and controlled implementation within the 90-day program window.
- Business objective: Transform NovaPay from manual, high-risk production deployments into an automated, observable, auditable and recoverable delivery platform.
- Target outcomes: multiple deployments per day; commit-to-production below 2 hours; MTTR below 15 minutes; five-nines availability objective; zero planned downtime; automated security/compliance gates; complete change-to-production evidence.
- Approval principle: Velocity is permitted only when risk controls remain blocking, measurable and auditable.

Slide 2 — Why Change Is Urgent: Current-State Risk

- Manual SSH deployments → human error, weak segregation of duties and poor traceability.
- No CI/CD pipeline → inconsistent release process and slow feedback.
- 3 production incidents in Q4 2025 → demonstrated change-related reliability risk.
- Deployment frequency once every 2 weeks → slow delivery and large change batches.
- MTTR 4.5 hours → extended customer/business impact.
- No automated compliance scanning + 17 RBI audit non-conformances → elevated regulatory risk.
- Manual DB migrations at 2 AM → operational and migration risk.
- Zero observability → customers detect incidents before systems.

Slide 3 — Risk Statement and Transformation Goals

- Core risk: NovaPay cannot safely increase delivery velocity while production changes remain manually deployed, weakly tested, poorly observed and difficult to recover.
- Delivery: trunk-based development, short-lived branches, mandatory review, protected main branch and automated pipeline execution.
- Security: SAST, dependency/CVE scanning, container scanning, SBOM, image signing/provenance and DAST.
- Compliance: OPA/Kyverno, RBI mapping, PCI-DSS v4.0, segregation of duties and immutable audit evidence.
- Reliability: blue-green/canary deployment, automated verification, Category A/B rollback and zero-downtime database migration.

Slide 4 — Target Solution Architecture

- Developer → Git/PR → Source Control → Build/Test → SAST → Dependency/Container/SBOM → Integration/Contract → DAST → Policy/Compliance → Deployment/Verification.
- Policy/compliance controls include RBI, PCI-DSS, SoD, OPA/Kyverno and Cosign/Notary.
- Deployment runs on Kubernetes using blue-green or canary traffic management with Istio.
- Prometheus/Grafana and Alertmanager provide monitoring, alerting and rollback signals.
- Design principle: security, compliance and verification are blocking controls, not post-release activities.

Slide 5 — Eight-Stage Pipeline and Control Points

- 1 Source control — controlled change entry: PR, review, signed commit.
- 2 Build — reproducible artifact: build result, version, Git SHA.
- 3 SAST — source security analysis.
- 4 Dependency/container — CVE result, SBOM, image scan.
- 5 Integration/contract — service compatibility.
- 6 DAST — runtime application security.
- 7 Policy/compliance — OPA/Kyverno, RBI/PCI/SoD results.
- 8 Deployment/verification — health, smoke, synthetic and SLO evidence.
- Artifact rule: build once and promote the same immutable artifact; never use a mutable 'latest' tag in production.

Slide 6 — Environment Promotion and Governance

- DEV → STAGING → PRE-PROD → PRODUCTION.
- Build once; promote the same artifact. Change configuration, not application code, between environments.
- Production requires independent Release Manager and SRE Lead approval.
- No mandatory gate may be bypassed.
- Emergency hotfixes may use an expedited path, but still pass security and compliance gates.
- Terraform provides infrastructure as code; Helm packages/configures applications; ArgoCD provides GitOps deployment; Kubernetes is the runtime; Istio manages traffic.

Slide 7 — RBI and PCI-DSS Compliance Control Model

- RBI: 4.2 change management; 4.3 segregation of duties; 5.1 vulnerability assessment; 5.4 encryption; 6.1 audit trails; 6.3 incident management/business continuity; 7.2 third-party risk.
- PCI-DSS v4.0: 6.2 bespoke software security; 6.3 vulnerabilities; 6.4 public-facing application protection; 6.5 change management; 10.2 audit logging; 11.3 security testing.
- Control objective: prove every production change was reviewed, tested, secured, approved, deployed and recoverable.

Slide 8 — Compliance Gates: Hard-Blocking Risk Controls

- G1 SAST; G2 DAST; G3 Dependency & CVE; G4 Licence compliance; G5 Kubernetes policy; G6 IaC security; G7 Image signing & provenance; G8 SoD / Change / Audit.
- Gate behavior: PASS → next stage. FAIL → pipeline stops → evidence recorded → remediation → rerun.
- Exceptions are allowed only through the approved exception workflow; they do not silently bypass governance.
- Evidence: PR review, scan reports, SBOM, policy results, image signature, approvals, deployment records and audit events.

Slide 9 — Risk Mitigation Strategy

- Bad code → unit/integration/SAST → monitoring → rollback.
- Vulnerable dependency → CVE/SBOM gate → security monitoring → block/rebuild.
- Runtime vulnerability → DAST/WAF → alerts → rollback.
- Unsafe Kubernetes/IaC → OPA/Kyverno → runtime monitoring → block/rollback.
- Unsigned image → Cosign/Notary + admission policy → deployment rejected.
- Unauthorized change → SoD/approvals → audit trail → freeze/investigate.
- Database incompatibility → expand-contract testing → DB/transaction monitoring → safe recovery.
- Performance regression → canary analysis → p99/CPU/queue → stop promotion/rollback.
- Incident → SLO alerts → Prometheus/Alertmanager → rapid rollback and evidence.

Slide 10 — Zero-Downtime Deployment Strategy

- Blue-green: stable environment receives traffic while candidate is validated; switch traffic after verification; reverse traffic for fast recovery.
- Canary: candidate progresses through controlled traffic percentages such as 5% → 10% → 25% → 50% → 100%, with analysis at each step.
- Verification includes startup/readiness/liveness probes, smoke tests, synthetic payment, HTTP 5xx, p99 latency, payment success and database health.
- Customer impact is checked before final promotion.

Slide 11 — Canary Analysis and Statistical Safety

- Latency comparison: Welch's t-test between stable and candidate distributions.
- Categorical success/error comparison: chi-squared test.
- Decision flow: stable vs canary → statistical checks → SLO checks → business checks → PASS / HOLD / ROLLBACK.
- Statistical significance does not replace operational thresholds; statistical and SLO/business evidence are evaluated together.

Slide 12 — Rollback Guarantees

- Category A, target <60s: HTTP 5xx >5% for 60s; 3 consecutive health failures; OOMKill; CrashLoopBackOff; DB connection-pool exhaustion; critical synthetic payment failure.
- Category B, target <15m: p99 >2× baseline for 5m; error-budget burn >10× normal for 10m; transaction success >2% below baseline; CPU >90% for 5m; memory >85% for 5m.
- Category C: gradual degradation below automated thresholds; customer-support reports; retroactive compliance failure; downstream dependency correlation.
- Workflow: Detect → Correlate → Freeze → Rollback → Verify → Notify → Incident → Postmortem.
- Rollback is independent of the primary deployment path.

Slide 13 — Zero-Downtime Database Migration

- Expand → Migrate → Verify → Contract.
- Expand: add backward-compatible schema. Migrate: application supports old and new schema; backfill in controlled batches. Verify: integrity, performance and transaction checks. Contract: remove obsolete schema only after safe adoption.
- Safety: avoid destructive first-step changes; test with running version; control locks/transactions; validate integrity; maintain explicit recovery plan.
- Application rollback is not the same as financial transaction rollback; reconciliation must be handled separately.
- The assessment requires the pattern to support very large financial tables without a maintenance window.

Slide 14 — Observability and SLO Model

- Metrics / Logs / Traces → Prometheus / Central Logging / Tracing → Grafana → Engineering / Management / Regulatory dashboards → Alertmanager.
- DORA: Deployment Frequency multiple/day; Lead Time <1 hour target in observability strategy; Change Failure Rate <5%; MTTR <1 hour dashboard target, with project incident objective <15 minutes.
- SLO: 99.9% availability in rollback/observability controls; 0.1% error budget.
- Key metrics: build success, queue depth, pipeline duration, compliance pass rate, deployment duration, rollback rate, 5xx, p99, payment success, CPU, memory, DB pool, RabbitMQ queue depth, pod restarts and alert/incident timing.

Slide 15 — Three Dashboard Views

- Engineering real-time: availability/SLO, 5xx, p99, payment success, traffic, CPU/memory, DB pool, pod health, Redis/RabbitMQ, deployment state, traffic split, active alerts and rollback signals.
- Management weekly/monthly: DORA trends, build success, compliance pass rate, rollback rate, incidents, customer impact, top risks and improvement actions.
- Regulatory audit-ready: production changes, approvals, RBI/PCI status, gate pass rates, commit → artifact → approval → deployment → verification, evidence completeness, exceptions, incidents/rollbacks and SoD evidence.

Slide 16 — Incident Response and Alert Escalation

- Metric/SLO → Prometheus → Alertmanager → severity classification → notification/automation → escalation → incident/rollback.
- Detect automatically wherever possible; correlate with deployment ID, version and Git SHA; freeze unsafe promotion; restore rapidly; verify; communicate; preserve evidence; complete postmortem.
- Evidence correlation: incident ID → alert → deployment → Git SHA → image digest → traffic state → rollback → verification.

Slide 17 — Business Impact and High-Traffic Risk

- NovaPay is a financial platform: reliability failures can affect payment success, customer trust, transaction processing, operational workload, regulatory scrutiny and reconciliation.
- High-traffic windows: salary days 1st/7th/15th; month-end 28th–31st; Diwali, Eid, Christmas, Holi; RBI settlement windows; regulatory filing deadlines; marketing campaigns.
- Deployments within 48 hours of high-traffic windows require performance-test consideration.
- Performance signals: CPU >70%, queue depth >1000, p99 latency >300ms.

Slide 18 — Infrastructure as Code and GitOps Delivery

- Terraform: pipeline/terraform/modules and pipeline/terraform/environments for repeatable infrastructure and environment consistency.
- Helm: pipeline/helm/novapay with Chart.yaml, values*.yaml and templates for application packaging and environment configuration.
- ArgoCD: pipeline/argocd/applications with dev, staging, preprod and production Applications for GitOps reconciliation.
- Governance: approved repository state is the source of truth for infrastructure/application deployment.

Slide 19 — 90-Day Implementation and Governance Roadmap

- Phase 1 Foundation: source control, branching, build/test automation, artifact versioning and initial Terraform/Helm/ArgoCD.
- Phase 2 Security/compliance: SAST, dependency/container scanning, SBOM, DAST, OPA/Kyverno, signing, RBI/PCI/SoD gates and evidence.
- Phase 3 Zero downtime: Kubernetes, blue-green, canary/Istio, expand-contract migration and rollback.
- Phase 4 Operations: Prometheus/Grafana, Alertmanager, SLO/error budget, synthetic monitoring and incident response.
- Phase 5 TRC readiness: end-to-end evidence review, incident simulation, cross-deliverable review, gap remediation and final approval.
- Each phase requires evidence, review and measurable acceptance criteria.

Slide 20 — TRC Q&A and Approval Conditions

- How do you prevent unsafe code? Mandatory testing, SAST, dependency/container, DAST and policy/compliance gates block promotion.
- What prevents unauthorized deployment? Protected branches, peer review, SoD, independent production approvals and audit records.
- What happens if production is unhealthy? Prometheus/Alertmanager detects defined conditions and the independent rollback process responds according to policy.
- How do you prove what changed? Commit → PR → gate evidence → artifact digest/signature → approval → deployment → verification → rollback/audit trail.
- How do you avoid DB downtime? Expand-contract migration with backward compatibility and controlled verification.
- Why can NovaPay deploy multiple times per day safely? Automation reduces manual error while hard security, compliance, progressive delivery, observability and rollback controls constrain risk.
- Approval conditions: mandatory gates remain blocking; production SoD remains enforced; rollback is independently available/tested; evidence is retained; SLO/incident controls are operational; high-traffic restrictions are enforced.
- Final recommendation: Approve controlled implementation subject to evidence-based validation of each production control.